

Blockchain, Cryptography & Cybersecurity

A complete concept guide — fundamentals, technical terms, mechanisms, formulas, and how the pieces connect

How to use this book: Start with Cryptography if the mathematical/security primitives are new to you. Then study Blockchain to see those primitives used inside a distributed system. Study Cybersecurity to understand how systems are attacked, defended, monitored, and recovered.

Scope: This document focuses on concepts and terminology. It intentionally does not include hackathon/project ideas.

Part I — Cryptography

Cryptography is the science of protecting information using mathematical algorithms, keys, and protocols. Modern cryptography is mainly concerned with confidentiality, integrity, authentication, and related security properties.

1. Core security goals

Term	Meaning
Confidentiality	Only authorized parties can read information.
Integrity	Data has not been altered in an unauthorized way.
Authentication	A party, message, or data origin can be verified.
Authorization	A verified identity is given or denied permission to perform an action.
Non-repudiation	A signature mechanism can provide evidence that a particular key holder authorized a message, subject to the protocol and key security.
Availability	Information or services remain accessible when needed. This is a broader security goal and is not provided by cryptography alone.

2. Mathematical model of cryptography

A cryptographic primitive can be represented mathematically. A hash function, for example, maps an arbitrary-length message to a fixed-length output:

$$H : \{0,1\}^* \rightarrow \{0,1\}^n$$

Here, $\{0,1\}^*$ means all finite binary strings and $\{0,1\}^n$ means binary strings of exactly n bits. A cryptographic algorithm is secure because of carefully defined properties and computational assumptions, not because the algorithm is secret. In modern design, the algorithm is normally public and the key is secret.

3. Hash functions

A **cryptographic hash function** takes input of arbitrary size and produces a fixed-size digest. Examples include SHA-256 and SHA-3. A hash is not encryption: there is normally no secret key and no intended decryption operation.

Term	Meaning
Digest / hash value	The fixed-length output produced by a hash function.
Preimage resistance	Given h , it should be computationally difficult to find m such that $H(m)=h$.
Second-preimage resistance	Given m , it should be difficult to find a different m' with $H(m)=H(m')$.
Collision resistance	It should be difficult to find any two distinct messages m, m' with the same hash.
Avalanche effect	A small input change should produce a substantially different digest.
Deterministic	The same input always produces the same output.
Birthday bound	For an ideal n -bit hash, generic collision search requires roughly $2^{n/2}$ work; for SHA-256 this is about 2^{128} .

Example: $H(\text{"hello"})$ always gives the same SHA-256 digest. If one character changes, the digest changes unpredictably.

4. Symmetric encryption

Symmetric cryptography uses the same secret key, or closely related secret material, for encryption and decryption. It is efficient and is widely used for protecting bulk data.

Typical model: $C = \text{Enc}(K, M)$, and $M = \text{Dec}(K, C)$, where M is plaintext, C is ciphertext, and K is the secret key.

Term	Meaning
AES	Advanced Encryption Standard. A block cipher with a 128-bit block size and 128-, 192-, or 256-bit keys.
Block cipher	An algorithm that transforms fixed-size blocks under a key.
Mode of operation	A construction that specifies how a block cipher processes longer messages, e.g. GCM.
Nonce	A value intended to be used once within a security context. In AEAD schemes, nonce reuse can be catastrophic.
IV	Initialization vector; a value used to initialize some encryption modes. Its exact requirements depend on the mode.
AEAD	Authenticated Encryption with Associated Data: encryption plus integrity/authentication for ciphertext and optional unencrypted associated data.
AES-GCM	An AEAD construction based on AES and Galois/Counter Mode.
ChaCha20-Poly1305	A widely used AEAD construction combining the ChaCha20 stream cipher with Poly1305 authentication.

5. Public-key cryptography

Public-key cryptography uses a key pair: a **private key** kept secret and a **public key** that can be distributed. Different schemes use the pair differently: encryption schemes can provide confidentiality, while signature schemes provide authenticity/integrity evidence.

Term	Meaning
Private key	Secret value that must be protected.
Public key	Value intended to be distributed.
Key pair	Related private/public keys generated together.
Asymmetric cryptography	Cryptography based on mathematically related public and private keys.
Hardness assumption	A computational problem believed to be infeasible to solve at required security levels, such as the elliptic-curve discrete logarithm problem.

6. Digital signatures

A digital signature is used to demonstrate that a message was authorized by whoever controls a private signing key and that the signed message has not been modified. Abstractly:

$\text{KeyGen}() \rightarrow (\text{sk}, \text{pk})$

$\text{Sign}(\text{sk}, m) \rightarrow \sigma$

$\text{Verify}(\text{pk}, m, \sigma) \rightarrow \{\text{true}, \text{false}\}$

Term	Meaning
Signature	Cryptographic value produced from a private key and message.
Verification	Public-key operation that checks whether a signature matches a message and public key.
ECDSA	Elliptic Curve Digital Signature Algorithm.
EdDSA	Edwards-curve Digital Signature Algorithm; Ed25519 is a widely used instance.
Ed25519	A signature system based on Edwards-curve techniques, designed for strong security and practical implementation.

7. Elliptic-curve cryptography

An elliptic curve over a finite field can be written in a form such as $y^2 = x^3 + ax + b$, with the exact representation depending on the field and curve. Cryptographic systems define a group of points and an operation usually described as point addition.

A central operation is scalar multiplication: kG , meaning adding the point G to itself according to the group operation k times. Computing kG is efficient, while recovering k from G and kG is intended to be computationally hard. This is the **elliptic-curve discrete logarithm problem (ECDLP)**.

8. MACs vs digital signatures

Term	Meaning
MAC	Message Authentication Code. Uses a shared secret to authenticate messages; examples include HMAC and Poly1305-based constructions.
HMAC	Hash-based Message Authentication Code, typically built from a cryptographic hash and secret key.
Digital signature	Uses a private key to sign and a public key to verify. Useful when verifiers do not share a secret with the signer.

Important: A MAC proves possession of a shared secret to parties that know that secret. A digital signature uses a public verification key and a private signing key.

9. Merkle trees

A **Merkle tree** is a tree of hashes used to commit efficiently to many pieces of data. Leaves represent data items; parent nodes are hashes of child hashes; the root is the final commitment.

For N leaves, a membership proof normally requires $O(\log N)$ sibling hashes. For about one million leaves, the proof path is roughly 20 levels because $\log_2(1,000,000) \approx 20$.

Term	Meaning
Merkle root	Top hash that commits to the tree's contents.
Merkle proof	Small set of hashes allowing a verifier to prove that a leaf belongs to the committed tree.
Hash pointer	A reference to data together with a cryptographic hash of that data, allowing integrity checking.

10. Commitments

A cryptographic commitment lets someone commit to a value without revealing it immediately. A common conceptual construction is $C = H(m \parallel r)$, where m is the message and r is random secret data.

Term	Meaning
Commit phase	Create and publish a commitment without revealing the underlying value.
Reveal phase	Later reveal the value and randomness so others can verify the commitment.
Hiding	The commitment should not reveal the committed value before reveal.
Binding	After committing, it should be difficult to change the committed value.

11. Zero-knowledge proofs

A **zero-knowledge proof (ZKP)** allows a prover to convince a verifier that a statement is true without revealing the secret information underlying the statement.

Term	Meaning
Prover	Party trying to prove a statement.
Verifier	Party checking the proof.
Completeness	True statements should be accepted by an honest verifier.
Soundness	False statements should not be accepted except with very small probability.
Zero knowledge	The verifier learns no useful information beyond the truth of the statement, according to the construction's formal definition.
zk-SNARK	Zero-Knowledge Succinct Non-Interactive Argument of Knowledge.
zk-STARK	Zero-Knowledge Scalable Transparent Argument of Knowledge.
PLONK	A family of universal/updatable proof systems based on polynomial commitments.
Groth16	A succinct zk-SNARK construction with widely studied practical performance characteristics.
Bulletproofs	A class of short non-interactive zero-knowledge proofs that can avoid a trusted setup in common constructions.

12. Randomness and CSPRNGs

Security protocols often need unpredictable values. A **CSPRNG** (cryptographically secure pseudorandom number generator) produces outputs intended to resist prediction by attackers. Weak randomness can expose private keys, nonces, tokens, or session secrets.

13. PKI and certificates

Public Key Infrastructure (PKI) is a system for managing public keys and certificates. In HTTPS, certificates bind a domain identity to a public key and are signed through a certificate authority hierarchy.

Term	Meaning
Certificate	Signed structured data binding an identity or domain to a public key.
Certificate Authority (CA)	Entity that issues and signs certificates under a trust system.
Root CA	Trusted certificate authority at the top of a certificate chain.
Certificate chain	Sequence of certificates leading from an end-entity certificate to a trusted root.

Part II — Blockchain

A **blockchain** is a replicated data/state system in which participants follow a protocol for accepting, ordering, validating, and committing updates. Cryptography provides integrity and authorization primitives, while networking and consensus coordinate independent participants.

1. Ledger and distributed ledger

Term	Meaning
Ledger	Record of transactions or state changes.
Distributed ledger	A ledger replicated across multiple participants.
Blockchain	A ledger/data structure where blocks are linked and accepted according to a consensus protocol.
Node	A computer participating in the blockchain network.
Peer-to-peer (P2P) network	Network in which nodes communicate directly rather than relying on one central server.

2. Block structure

A typical block contains a **header** and a **body**. Exact fields differ between blockchains.

Term	Meaning
Block header	Metadata used to identify and validate a block.
Previous block hash	Hash/reference linking a block to an earlier block.
Timestamp	Protocol-defined time metadata; its exact trust properties vary.
Merkle root	Commitment to transactions or other data in a block.
Block body	Transactions or other protocol data included in the block.
Block hash	Digest derived from block data under the protocol's hashing rules.

The chain relationship can be viewed as: Block n contains a commitment to Block $n-1$. Changing an earlier block therefore changes its hash and breaks later links, although protocol-specific attack models determine what an attacker could rebuild or replace.

3. Transactions

A **transaction** is a proposed state change. A transaction commonly contains sender/account information, destination or contract information, value/data, a nonce or sequence value, and a cryptographic signature, depending on the blockchain.

Conceptual lifecycle:

User → construct transaction → sign → broadcast → nodes validate → transaction enters a pool → proposer includes it in a block → consensus accepts block → nodes execute/apply state transition.

4. Transaction validation

Term	Meaning
Signature validation	Checks that the transaction is authorized by the relevant private key.
Nonce / sequence number	Protocol-specific value used to order transactions and/or prevent replay.
Replay attack	Reuse of a valid message/transaction in an unintended context.
Double spending	Attempt to spend the same asset/value more than once.
Mempool	Local or network-level pool of transactions waiting for inclusion; exact behavior varies by chain.

5. Node types

Term	Meaning
Full node	Maintains enough blockchain data and validation logic to independently verify protocol rules.
Validator	Participant responsible for consensus duties in proof-of-stake systems.
Proposer	Participant selected to propose a block in a particular consensus round.
Archive node	Node retaining extensive historical state/data, depending on chain design.
Light client	Client that verifies or obtains limited information without storing the entire chain.
RPC node/service	Interface through which applications submit requests or transactions and query blockchain data.

6. Gossip and networking

Blockchain nodes disseminate transactions and blocks through peer-to-peer protocols, often using **gossip**: a node sends information to selected peers, who relay it further. Networking introduces latency, dropped messages, partitions, and adversarial peers, all of which consensus protocols must tolerate within their threat model.

7. Consensus

Consensus is the protocol process by which distributed participants agree on the valid ordering/state of updates.

Proof of Work (PoW)

In PoW, participants search for a value such as a nonce that makes a block header satisfy a computational target. This creates a cost for proposing blocks. Security depends on assumptions about computational power and network conditions.

Term	Meaning
Nonce	Variable changed during PoW search or used for other protocol purposes.
Difficulty	Parameter controlling how difficult a valid PoW solution is.
Target	Threshold a block hash must satisfy under the PoW rules.
Hashrate	Aggregate computational hashing rate of miners or the network.

Term	Meaning
Mining	Process of performing PoW and proposing blocks in PoW systems.

Proof of Stake (PoS)

PoS selects or weights participants according to staked economic resources. Validators perform protocol duties such as proposing and attesting to blocks. Many PoS systems include penalties or **slashing** for defined forms of protocol misconduct.

Term	Meaning
Stake	Economic value locked or committed to participate in consensus.
Validator	Participant performing consensus duties.
Attestation / vote	Protocol message expressing support for a block or chain state.
Slashing	Protocol penalty for specified validator behavior.
Economic security	Security derived partly from the economic cost of violating protocol rules.

8. Finality

Term	Meaning
Probabilistic finality	Confidence that a transaction will remain in the canonical chain increases as more blocks build on it.
Deterministic / protocol finality	A protocol rule can establish that a finalized state cannot be reverted except under extraordinary protocol-level conditions.
Canonical chain	Chain/state selected as authoritative by the protocol.

9. Forks

Term	Meaning
Fork	Situation where protocol history or rules diverge into different paths.
Temporary fork	Short-lived competing histories that may resolve when the protocol chooses one.
Soft fork	Protocol-rule change designed to remain compatible with old behavior in a defined sense.
Hard fork	Protocol-rule change that can make previously valid blocks/transactions invalid to upgraded rules or otherwise splits compatibility.

10. State and state transitions

A blockchain is not only a history of transactions; many platforms maintain a current **state**: balances, contract storage, account information, and other protocol data.

A useful abstraction is: $S_{t+1} = F(S_t, T_t)$, where S_t is current state, T_t is an accepted transaction set, and F is deterministic state-transition logic.

11. Smart contracts and virtual machines

A **smart contract** is program code deployed to a blockchain and executed according to deterministic protocol rules. Ethereum, for example, uses the **EVM (Ethereum Virtual Machine)**.

Term	Meaning
Smart contract	On-chain program that changes state according to its code and protocol rules.
EVM	Ethereum Virtual Machine, the execution environment for Ethereum smart contracts.
Bytecode	Machine-readable code executed by a virtual machine.
ABI	Application Binary Interface describing how software encodes/decodes calls and data for a contract.
Deterministic execution	All honest nodes should obtain the same result from the same valid state and transaction inputs.

12. Gas and transaction fees

Gas represents computational/storage work under Ethereum-like execution models. A transaction specifies fee-related parameters so validators/proposers are compensated and scarce block resources are priced.

Term	Meaning
Gas limit	Maximum gas a transaction is allowed to consume.
Gas used	Actual execution resource consumption under the protocol's accounting.
Gas price / fee parameters	Values determining how much the sender pays for execution; exact model varies by chain.

13. Tokens

Term	Meaning
ERC-20	Ethereum standard interface commonly used for fungible tokens.
ERC-721	Ethereum standard commonly used for non-fungible tokens (NFTs).
Fungible	Units are interchangeable, like identical monetary units.
Non-fungible	Each token is represented as a distinct item/identifier.
NFT	Non-fungible token; an on-chain representation with unique identity under a token standard.

14. Layer 1 and Layer 2

Layer 1 (L1) is the base blockchain network. **Layer 2 (L2)** systems execute or batch activity with the goal of improving throughput/cost while relying on an L1 for some security or settlement properties.

Term	Meaning
Rollup	System that executes/batches transactions and posts data or commitments to a base chain.
Optimistic rollup	Rollup model that generally assumes posted results are valid unless challenged during a defined dispute process.
ZK rollup	Rollup that uses zero-knowledge proofs to demonstrate correctness of state transitions.
Bridge	Protocol/system enabling assets or messages to move between blockchain environments; bridges have their own security assumptions.

15. MEV and transaction ordering

MEV (Maximal Extractable Value) refers to value that can arise from controlling transaction ordering or block construction. Ordering can affect arbitrage, liquidations, and other application outcomes. This makes transaction ordering a security/economic design concern.

16. Oracles

Smart contracts generally cannot directly trust arbitrary external information. An **oracle** provides external data to on-chain systems. Oracle security concerns include data correctness, manipulation, availability, and incentive design.

17. Blockchain security terms

Term	Meaning
Sybil attack	An attacker creates many identities to gain influence in a system where identity count matters.
51% attack	Informal term for an attacker controlling a majority of relevant consensus resource in some PoW/PoS threat models; consequences depend on the specific protocol.
Reorganization (reorg)	Change in the previously observed chain history due to a competing canonical history.
Bridge vulnerability	Failure in a cross-chain mechanism that can allow unauthorized asset/message movement or incorrect state.
Smart-contract vulnerability	Bug or design flaw in on-chain code that causes unintended behavior.

Part III — Cybersecurity

Cybersecurity is the discipline of protecting systems, networks, software, data, identities, and services from unauthorized access, disruption, alteration, destruction, and abuse.

1. CIA triad

Term	Meaning
Confidentiality	Prevent unauthorized disclosure.
Integrity	Prevent or detect unauthorized modification.
Availability	Keep systems/data accessible and operational.

2. AAA

Term	Meaning
Authentication	Who are you?
Authorization	What are you allowed to do?
Accounting / Auditing	What happened, when, and by whom?
Identity	Representation of a user, service, device, or other principal.
Principal	Entity that can be authenticated and authorized.

3. Networking foundations

Term	Meaning
IP address	Logical network address used for routing.
MAC address	Link-layer identifier associated with a network interface.
TCP	Connection-oriented transport protocol providing ordered, reliable byte-stream delivery.
UDP	Connectionless transport protocol with low overhead and no built-in delivery guarantee.
DNS	Domain Name System; maps names such as example.com to network-related records.
HTTP	Application protocol used for web communication.
HTTPS	HTTP protected using TLS.
TLS	Transport Layer Security; cryptographic protocol providing confidentiality, integrity, and authentication properties for network connections.
ARP	Address Resolution Protocol used in IPv4 local networks to map IP addresses to link-layer addresses.

Term	Meaning
DHCP	Protocol for dynamically assigning network configuration such as IP addresses.
ICMP	Internet Control Message Protocol used for network control/error reporting and diagnostic messages.
SSH	Secure Shell protocol for secure remote administration and related communication.
SMTP	Simple Mail Transfer Protocol used for email transfer.

4. TCP three-way handshake

A typical TCP connection begins with SYN → SYN-ACK → ACK. This establishes connection state and synchronizes sequence information. TCP then provides ordered, reliable byte-stream delivery using acknowledgments, retransmission, flow control, and congestion control.

5. DNS

A simplified DNS lookup can involve a client resolver, recursive resolver, root servers, top-level-domain servers, and authoritative name servers. DNS attacks can include cache poisoning, malicious domain infrastructure, DNS tunneling, and denial-of-service techniques.

6. HTTPS and TLS

TLS typically uses asymmetric cryptography during connection establishment to authenticate parties and establish shared keying material, then uses efficient symmetric AEAD encryption for application data.

Conceptually: certificate validation → key exchange/authentication → session keys → encrypted application traffic.

Term	Meaning
Session key	Symmetric key used for a particular secure communication session.
Handshake	Protocol phase that negotiates parameters and establishes authentication/keying.
Certificate validation	Checking that a certificate chains to a trusted authority and is valid for the intended identity under the protocol/client rules.

7. Firewalls

A **firewall** controls network traffic according to rules. It can filter by addresses, ports, protocols, connection state, application characteristics, or other context depending on the technology.

Term	Meaning
Ingress	Traffic entering a system/network.
Egress	Traffic leaving a system/network.
Stateful firewall	Tracks connection state when applying filtering rules.
Network segmentation	Separating networks or systems to limit unnecessary communication and contain incidents.

8. IDS and IPS

Term	Meaning
IDS	Intrusion Detection System. Detects suspicious activity and generates alerts.
IPS	Intrusion Prevention System. Detects and can actively block or disrupt suspicious traffic.
Signature-based detection	Matches known patterns of malicious activity.
Anomaly-based detection	Looks for deviations from learned or defined normal behavior.

9. SIEM, logs, and monitoring

A **SIEM (Security Information and Event Management)** platform collects and correlates security-relevant events from multiple sources. Useful sources include authentication logs, endpoint telemetry, firewall events, cloud audit logs, DNS logs, and application logs.

Term	Meaning
Log	Recorded event information.
Event correlation	Connecting events from different systems to identify a broader activity pattern.
IOC	Indicator of Compromise; observable evidence associated with possible malicious activity.
TTP	Tactics, Techniques, and Procedures describing how threat actors operate.
Alert	Notification generated when a detection rule or analytical system identifies suspicious behavior.

10. Malware

Term	Meaning
Malware	Malicious software.
Virus	Malware that typically attaches to another file/program and relies on execution/spread mechanisms.
Worm	Malware capable of self-propagation across systems/networks.
Trojan	Malicious program disguised as or delivered as something apparently legitimate.
Ransomware	Malware that commonly blocks access to data/systems and demands payment; modern cases may also involve data theft.
Spyware	Software designed to collect information without appropriate authorization.
Rootkit	Techniques/software designed to hide malicious presence or maintain privileged access.
Bot	Compromised device controlled as part of a larger system; botnets are networks of such devices.

11. Phishing and social engineering

Social engineering attacks human decision-making rather than relying only on technical vulnerabilities. **Phishing** uses deceptive messages or pages to induce victims to reveal credentials, execute actions, or transfer information.

Term	Meaning
Spear phishing	Targeted phishing against a specific person or organization.
Credential harvesting	Fraudulently collecting usernames, passwords, tokens, or similar authentication material.
MFA	Multi-factor authentication; requires multiple independent authentication factors.
Factor	Something you know, have, or are, depending on the authentication scheme.

12. Password security

Passwords should not normally be stored as plaintext. Password storage uses password-hashing/KDF algorithms designed to make large-scale guessing expensive.

Term	Meaning
Salt	Random per-password value stored with the password hash to prevent identical passwords from producing identical stored values and to defeat precomputed tables.
Argon2id	Modern memory-hard password hashing/KDF option.
bcrypt	Password hashing algorithm designed to make password guessing more expensive.
scrypt	Memory-hard password KDF.
PBKDF2	Password-based key derivation function using repeated computation.
Brute force	Systematically trying many possible credentials/keys.
Credential stuffing	Trying leaked username/password pairs against other services.

13. SQL injection

SQL injection occurs when untrusted input changes the intended structure of a database query. The fundamental defense is to keep data separate from SQL syntax, usually through parameterized queries/prepared statements, along with least privilege and appropriate validation.

Core principle: never construct security-sensitive SQL by directly concatenating untrusted input into query syntax.

14. Cross-site scripting (XSS)

Term	Meaning
XSS	Injection of attacker-controlled content that executes in a victim's browser under the application's origin.

Term	Meaning
Stored XSS	Malicious content is stored by the application and later served to victims.
Reflected XSS	Malicious input is reflected immediately in a response.
DOM-based XSS	Client-side code causes unsafe interpretation/execution based on attacker-controlled data.
Output encoding	Encoding data according to its output context so it is treated as data rather than executable markup/script.
Content Security Policy (CSP)	Browser security policy that can restrict script sources and reduce XSS impact.

15. CSRF

Cross-Site Request Forgery (CSRF) abuses a victim's authenticated browser context to cause an unwanted state-changing request. Common defenses include anti-CSRF tokens, SameSite cookie settings, and appropriate origin checks.

16. Broken access control

Authentication answers *who*; authorization answers *what that identity may do*. Broken access control occurs when an application fails to enforce authorization correctly. A common pattern is exposing an object identifier and trusting the client instead of verifying that the authenticated user is authorized to access that object.

17. Sessions and JWTs

Term	Meaning
Session	Server/client state representing an authenticated interaction.
Session cookie	Browser cookie carrying a session identifier or related credential.
HttpOnly	Cookie attribute preventing ordinary JavaScript access to the cookie.
Secure	Cookie attribute instructing the browser to send it only over HTTPS.
SameSite	Cookie attribute controlling cross-site sending behavior.
JWT	JSON Web Token; structured signed token commonly used to carry claims.
Claim	Statement/value contained in a token.
JWS	JSON Web Signature; provides integrity/authenticity for a signed JWT-style object.
JWE	JSON Web Encryption; provides encryption for a JWT-style object.

Important: A typical signed JWT is not automatically encrypted. Its payload can usually be decoded by anyone who possesses the token; the signature protects integrity/authenticity, not confidentiality.

18. SSRF

Server-Side Request Forgery (SSRF) occurs when an attacker can influence a server into making requests to unintended destinations. Risk can include access to internal services, cloud metadata endpoints, or privileged network locations. Defenses include strict destination allowlists, network egress controls, URL parsing/validation, and isolation.

19. Path traversal

Path traversal occurs when user-controlled path components allow access outside an intended directory. Secure file APIs, canonicalization, allowlists, sandboxing, and least privilege reduce risk.

20. Command injection

Command injection occurs when untrusted input is interpreted as operating-system command syntax. The preferred design is to avoid shell invocation when possible and pass structured arguments to APIs. If shell execution is unavoidable, use strict allowlists and safe process APIs.

21. Vulnerability, threat, risk

Term	Meaning
Vulnerability	Weakness that can be exploited or otherwise cause a security failure.
Threat	Potential source or circumstance capable of causing harm.
Threat actor	Person, group, malware, or other entity capable of carrying out malicious activity.
Exploit	Technique or code that takes advantage of a vulnerability.
Risk	Combination of likelihood and impact under a defined risk model.
Attack surface	All exposed interfaces, services, code paths, identities, and other points that could be targeted.

22. Defense principles

Term	Meaning
Least privilege	Give users/processes only the permissions required for their tasks.
Defense in depth	Use multiple independent security controls so failure of one does not imply total compromise.
Zero Trust	Security architecture based on continuously verifying identity/context and not automatically trusting network location.
Secure by design	Build security requirements and controls into architecture and development rather than adding them only at the end.
Fail secure	When a failure occurs, default behavior should avoid granting unintended access.
Separation of duties	Separate sensitive responsibilities so one compromised account/person cannot perform every critical action.

23. Threat modeling and STRIDE

Threat modeling systematically identifies assets, trust boundaries, attack paths, and security requirements. **STRIDE** is a common Microsoft-originated model:

Term	Meaning
S — Spoofing	Pretending to be another identity.
T — Tampering	Unauthorized modification of data.
R — Repudiation	Difficulty proving who performed an action.
I — Information disclosure	Unauthorized exposure of information.
D — Denial of service	Reducing availability.
E — Elevation of privilege	Obtaining permissions beyond those authorized.

24. Secure SDLC

Security should be integrated across requirements, design, coding, testing, deployment, and maintenance.

Term	Meaning
SAST	Static Application Security Testing; analyzes source/bytecode without executing the application.
DAST	Dynamic Application Security Testing; tests a running application.
SCA	Software Composition Analysis; identifies risks in third-party dependencies.
Code review	Human/automated inspection of code for correctness and security issues.
Patch management	Process for applying security and reliability updates.

25. Incident response

Incident response handles suspected or confirmed security incidents. A common lifecycle is:

Preparation → Detection & Analysis → Containment → Eradication → Recovery → Lessons Learned

Term	Meaning
Containment	Limit damage and prevent further spread.
Eradication	Remove the cause/persistence of the incident.
Recovery	Restore systems and operations safely.
Forensics	Collection and analysis of evidence to understand events.
Chain of custody	Documentation showing how evidence was collected, handled, transferred, and preserved.

26. EDR and endpoint security

EDR (Endpoint Detection and Response) monitors endpoint behavior such as process creation, network connections, file activity, persistence mechanisms, and authentication events. It supports detection, investigation,

and response.

27. Vulnerability scanning vs penetration testing

Term	Meaning
Vulnerability scanning	Automated identification of known or suspected weaknesses.
Penetration testing	Authorized security testing designed to validate whether weaknesses can be exploited within a defined scope.
Red team	Authorized adversarial simulation focused on testing organizational detection and response as well as defenses.
Blue team	Defensive team responsible for monitoring, detection, response, and hardening.
Purple team	Collaborative approach where offensive and defensive teams use findings to improve detection and defense.

Part IV — How the Three Domains Connect

These are not isolated subjects. **Cryptography** supplies mathematical security primitives. **Blockchain** combines cryptography with distributed networking, state machines, and consensus. **Cybersecurity** applies security principles across networks, applications, identities, endpoints, people, and operations.

Example: a blockchain transaction

1. A wallet constructs transaction data.
2. The wallet signs the transaction with a private key.
3. Nodes verify the signature and protocol rules.
4. The transaction is propagated through the P2P network.
5. A consensus participant includes it in a block.
6. Other nodes verify the block, transactions, and consensus rules.
7. The accepted transaction changes blockchain state.
8. Hashes/Merkle commitments provide integrity structures, while consensus determines the protocol's accepted history.

Example: HTTPS

1. A client connects to a server.
2. TLS authenticates the server using certificates and public-key mechanisms.
3. The handshake establishes session key material.
4. Application traffic is protected using efficient symmetric AEAD encryption.
5. Integrity checks prevent undetected modification under the protocol's security guarantees.

Core mental model

Cryptography asks: How can we mathematically protect or authenticate information?

Blockchain asks: How can independent participants agree on a shared state/history without a single trusted database operator?

Cybersecurity asks: How do we protect the complete system against technical and human threats, detect failures, respond to incidents, and recover?

Essential terminology checklist

Term	Meaning
Hash	Fixed-length cryptographic digest.
Encryption	Transformation providing confidentiality using cryptographic keys.
AEAD	Authenticated encryption with associated data.
Key pair	Private/public cryptographic keys.
Signature	Publicly verifiable authorization/integrity evidence.
Merkle tree	Hash tree enabling efficient membership proofs.
Zero knowledge	Proving a statement without revealing the underlying secret information beyond the proof's intended leakage.
Consensus	Protocol mechanism for agreement on accepted state/history.
Smart contract	Deterministic on-chain program.

Term	Meaning
Gas	Execution-resource accounting used by some blockchains.
Mempool	Pool of pending transactions.
Oracle	Mechanism supplying external information to a blockchain.
Firewall	Traffic control mechanism.
IDS/IPS	Detection/prevention systems for suspicious network activity.
SIEM	Centralized security event collection/correlation platform.
MFA	Authentication using multiple factors.
XSS	Browser-side injection vulnerability.
CSRF	Cross-site request-forgery vulnerability.
SSRF	Server-side request-forgery vulnerability.
Least privilege	Minimum necessary permissions.
Threat model	Structured representation of assets, threats, trust boundaries, and defenses.
Incident response	Process for detecting, containing, eradicating, and recovering from security incidents.